

Dokumentacja projektu BIWO

System informatyczny przedszkola z uwierzytelnianiem, autoryzacją RBAC i REST API

Opracowanie na podstawie materiału w BIWO, pliku BIWO - projekt.pdf oraz analizy kodu aplikacji React + Spring Boot.

1. Cel dokumentu

Dokument opisuje, co zostało zaprojektowane i zaimplementowane w systemie przedszkola, jakie wymagania z zadania BIWO zostały spełnione, czego nie ma w obecnej wersji oraz z jakiego powodu nie zostało to ujęte. Nacisk położono na bezpieczeństwo, kontrolę dostępu, rolę użytkowników oraz strukturę REST API.

2. Kontekst zadania BIWO

Materiały BIWO wskazują, że bezpieczeństwo powinno być uwzględnione już w fazie projektowania. Projekt miał obejmować analizę roli, zasobów, operacji oraz zasad autoryzacji użytkowników. Wymagany rezultat to lista endpointów REST API, tabela ról i uprawnień oraz krótki opis ich działania i odpowiedzi.

- Zastosowano model RBAC, czyli kontrolę dostępu opartą na rolach.
- Zaprojektowano zasoby API związane z przedszkolem: rodzice, dzieci, komunikaty, jadłospis, uwagi i zdarzenia bezpieczeństwa.
- Uwzględniono zasadę, że każdy endpoint wymaga poprawnego tokena JWT, a publiczne są tylko wybrane odczyty oraz logowanie/rejestracja.

3. Charakterystyka systemu

Projekt jest aplikacją webową dla przedszkola. Frontend został wykonany w React, a backend w Spring Boot. Dane są przechowywane w PostgreSQL, a schemat bazy rozwijany jest przez migracje Flyway. Aplikacja działa lokalnie w środowisku Docker Compose.

Warstwa	Technologia	Rola w systemie
Frontend	React + Vite	Panel użytkownika: logowanie, dzieci, komunikaty, jadłospis, panel ośb.
Backend	Spring Boot	REST API, logika biznesowa, JWT, RBAC, obsługa bazy danych.
Baza danych	PostgreSQL + Flyway	Trwałe przechowywanie rodziców, dzieci, posiłków, komunikatów, uwag i logów security.
Uruchomienie	Docker Compose	Lokalne zestawienie frontendu, backendu i bazy danych.

4. Role użytkowników

Rola	Zakres odpowiedzialności
Niealogowany użytkownik	Może przeglądać publiczne komunikaty i jadłospis oraz skorzystać z logowania/rejestracji.
RODZIC	Ma dostęp do panelu własnych dzieci oraz wybranych informacji przypisanych do dziecka.
NAUCZYCIEL	Może dodawać uwagi i zarządzać jadłospisem w zakresie tworzenia oraz edycji.
DYREKCJA	Może zarządzać dziećmi, rodzicami, komunikatami, jadłospisem oraz przeglądać dane administracyjne.
ADMIN	Ma najwyższe uprawnienia, w tym usuwanie rodziców i dostęp do panelu administracyjnego.

W projekcie role są przechowywane w modelu Rodzic jako wartość enum Rola. W tokenie JWT rola trafia do claimu `rola`, a Spring Security mapuje ją na uprawnienia `ROLE_RODZIC`, `ROLE_NAUCZYCIEL`, `ROLE_DYREKCJA` albo `ROLE_ADMIN`.

5. Co jest zaimplementowane

5.1. Uwierzytelnianie i sesja JWT

- Endpoint `POST /api/auth/login` sprawdza email i hasło, a po poprawnym logowaniu zwraca token JWT.
- Token zawiera email użytkownika w subject oraz rolę w claimie `rola`.
- Token wygasa po 1 godzinie, co ogranicza czas użycia przebiegu tokena.
- Frontend zapisuje token w `localStorage` i do czasu go do zapytań wymagających autoryzacji.

5.2. Bezpieczne przechowywanie haseł

- Nowe hasła są zapisywane przez `BCrypt`, a nie jako tekst jawny.
- W kodzie pozostawiono zgodność wsteczną dla starszych danych demonstracyjnych, które mogły być zapisane przed hashowaniem.

5.3. Ograniczanie prób logowania i logi bezpieczeństwa

- Po 5 błędnych próbach logowania konto/email jest blokowane na 15 minut.
- System zapisuje zdarzenia `LOGIN_SUCCESS`, `LOGIN_FAILED` i `LOGIN_BLOCKED` do tabeli `security_event`.
- Dostęp do `/api/admin/security-events` mają tylko role `DYREKCJA` i `ADMIN`.

5.4. Kontrola dostępu RBAC

Reguły RBAC są zdefiniowane w SecurityConfig. Publiczne są logowanie, rejestracja, dokumentacja Swagger oraz odczyt opublikowanych komunikatów i jadłospisu. Pozostałe operacje wymagają tokena i odpowiedniej roli.

Obszar	Publiczne	RODZIC	NAUCZYCIEL	DYREKCJA	ADMIN
Komunikaty - odczyt	TAK	TAK	TAK	TAK	TAK
Komunikaty - zarządzanie	NIE	NIE	NIE	TAK	TAK
Jadłospis - odczyt	TAK	TAK	TAK	TAK	TAK
Jadłospis - dodanie/edycja	NIE	NIE	TAK	TAK	TAK
Jadłospis - usunięcie	NIE	NIE	NIE	TAK	TAK
Dzieci rodzica	NIE	TAK	TAK	TAK	TAK
Panel administracyjny dzieci	NIE	NIE	NIE	TAK	TAK
Rodzice - lista/dodanie/edycja	NIE	NIE	NIE	TAK	TAK
Rodzice - usunięcie	NIE	NIE	NIE	NIE	TAK
Uwagi - lista/dodanie	NIE	NIE	TAK	TAK	TAK
Logi bezpieczeństwa	NIE	NIE	NIE	TAK	TAK

5.5. Zasoby i endpointy REST API

Metoda	Endpoint	Dostęp	Opis
POST	/api/auth/login	publiczny	Logowanie i zwrot tokena JWT.
POST	/api/auth/register	publiczny	Rejestracja konta rodzica.
GET	/api/posts	publiczny	Lista opublikowanych komunikatów.
GET	/api/posts/{id}	publiczny	Podgląd opublikowanego komunikatu.
GET/POST/PUT/DELETE	/api/admin/posts	DYREKCJA, ADMIN	Administracyjne zarządzanie komunikatami.
GET	/api/posilki	publiczny	Lista wpisów w jadłospisu.
POST/PUT	/api/posilki	NAUCZYCIEL, DYREKCJA, ADMIN	Dodawanie i edycja jadłospisu.
DELETE	/api/posilki/{id}	DYREKCJA, ADMIN	Usuwanie wpisu jadłospisu.
GET	/api/rodzice/me/dzieci	zalogowany użytkownik	Dzieci przypisane do aktualnego użytkownika.
GET	/api/admin/dzieci	DYREKCJA, ADMIN	Lista wszystkich dzieci.
POST/PUT/DELETE	/api/admin/dzieci	DYREKCJA, ADMIN	CRUD dzieci.

E			
GET/POST/PUT	/api/rodzice	DYREKCJA, ADMIN	Lista, dodanie i edycja rodzic?w.
DELETE	/api/rodzice/{id}	ADMIN	Usuni?cie rodzica.
GET	/api/uwagi/dziecko/{idDziecka}	RODZIC, NAUCZYCIEL, DYREKCJA, ADMIN	Uwagi przypisane do dziecka.
GET/POST	/api/uwagi	NAUCZYCIEL, DYREKCJA, ADMIN	Lista i dodawanie uwag.
GET	/api/admin/security-events	DYREKCJA, ADMIN	Ostatnie zdarzenia bezpiecze?stwa.

5.6. Frontend

- Ekran logowania obs?uguje logowanie przez /api/auth/login.
- Panel dzieci pokazuje rodzicowi jego dzieci, a dyrekcji/adminowi list? dzieci w systemie.
- Widok komunikat?w jest publiczny, a dodawanie komunikat?w jest widoczne dla DYREKCJI i ADMINA.
- Widok jad?ospisu jest publiczny, a dodawanie posi?k?w jest widoczne dla NAUCZYCIELA, DYREKCJI i ADMINA.
- Widok ?Osoby i dzieci? jest dost?pny dla DYREKCJI i ADMINA; umo?liwia podgl?d os?b i dzieci oraz dodanie konta rodzica.

6. Czego nie ma w obecnej wersji i dlaczego

Brak / ograniczenie	Dlaczego nie ma w obecnej wersji
MFA, czyli uwierzytelnianie wielosk?adnikowe	Projekt skupia si? na podstawowym REST API z RBAC. MFA wymaga dodatkowego kana?u potwierdze?, konfiguracji u?ytownika i obs?ugi kod?w jednorazowych, co wykracza poza zakres zadania.
Reset has?a i odzyskiwanie konta	Nie jest wymagane do pokazania modelu RBAC. Funkcja wymaga poczty, token?w resetuj?cych i dodatkowych regu? bezpiecze?stwa.
Pe?ne szyfrowanie danych osobowych w bazie	Has?a s? hashowane, ale dane takie jak email i telefon nie s? szyfrowane. W projekcie lokalnym wa?niejsze by?o pokazanie kontroli dost?pu i integralno?ci danych; szyfrowanie p?l wymaga?oby zarz?dzania kluczami.
Rozbudowana walidacja ka?dego pola wej?ciowego	Cz??? p?l jest wymagana po stronie frontendu i bazy, ale brak pe?nych adnotacji walidacyjnych DTO. Dodanie Bean Validation by?oby naturalnym kolejnym krokiem.
Pe?ny panel CRUD dla wszystkich zasob?w w UI	Backend posiada wi?cej endpoint?w ni? frontend. Interfejs pokazuje najwa?niejsze scenariusze demonstracyjne, a pe?na administracja wymaga?aby dodatkowych formularzy edycji i usuwania.
Obs?uga zapis?w na zaj?cia dodatkowe i sto??wk? w API	Tabele i modele istniej? w bazie, ale endpointy nie zosta?y wystawione. Priorytetem projektu BIWO by?a kontrola dost?pu, nie pe?na funkcjonalno?? przedszkola.
Hierarchiczne RBAC lub wiele r?l na	System u?ywa jednej roli na konto. To prostsze i wystarczaj?ce do pokazania

użytkownika	podziału RODZIC/NAUCZYCIEL/DYREKCJA/ADMIN.
Zaawansowany monitoring produkcyjny	Jest prosty dziennik zdarzeń bezpieczeństwa, ale brak integracji z zewnętrznym SIEM lub alertami. To element typowy dla wdrożenia produkcyjnego, nie dla projektu lokalnego.
Ograniczenie logowania według lokalizacji/IP	Materiały BIWO wspominają o takim podejściu, ale implementacja wymaga reguł organizacyjnych i infrastruktury. W projekcie zastosowano prostszą blokadę po liczbie prób.
Testy penetracyjne i formalny raport OWASP	Projekt uwzględnił OWASP na poziomie projektowym, ale nie zawiera osobnego procesu testów bezpieczeństwa. Takie testy powinny być wykonywane w kontrolowanym zakresie i za zgodą właściciela systemu.

7. Uzasadnienie decyzji projektowych

Wybór JWT wynika z charakteru REST API: backend jest bezstanowy, a każde zapytanie niesie własny dowód uwierzytelnienia. BCrypt ogranicza skutki ewentualnego wycieku bazy, ponieważ hasła nie są przechowywane jawnie. RBAC został wybrany, ponieważ wymagania projektu naturalnie dzielą użytkowników według odpowiedzialności: rodzic, nauczyciel, dykcja i administrator.

Nie wszystkie funkcje przedszkola zostały rozwinięte do pełnego produktu. Zakres projektu koncentruje się na bezpieczeństwie aplikacji webowej: uwierzytelnianiu, autoryzacji, rozdzieleniu endpointów publicznych i chronionych, logowaniu zdarzeń oraz zabezpieczeniu operacji administracyjnych.

8. Odniesienie do OWASP i zasad bezpieczeństwa

- Broken Access Control: ograniczany przez centralne reguły SecurityConfig i role przypisane do endpointów.
- Identification and Authentication Failures: ograniczane przez BCrypt, JWT z czasem wygaśnięcia, jednakowy komunikat błędów logowania oraz blokadę po błędnych próbach.
- Security Logging and Monitoring Failures: częściowo ograniczane przez tabelę security_event i endpoint dla administracji.
- Injection: projekt korzysta z Spring Data JPA/ORM, co ogranicza potrzebę ręcznego składowania zapytań SQL.
- Insecure Design: ryzyko zmniejszono przez zaprojektowanie roli i uprawnień przed opisem endpointów.

9. Konta demonstracyjne

Email	Hasło	Rola
admin@test.pl	admin123	ADMIN
dykcja@test.pl	dykcja123	DYREKCJA
nauczyciel@test.pl	nauczyciel123	NAUCZYCIEL

rodzic@test.pl	rodzic123	RODZIC
----------------	-----------	--------

10. Podsumowanie

Projekt spełnia główne wymagania zadania BIWO: zawiera REST API, zasoby, endpointy CRUD, role, macierz uprawnień i mechanizmy autoryzacji. Dodatkowo implementuje praktyczne elementy bezpieczeństwa, takie jak JWT, BCrypt, ograniczanie prędkości logowania i logowanie zdarzeń. Braki dotyczą głównie funkcji produkcyjnych lub rozszerzeń, które nie były konieczne do demonstracji RBAC i bezpieczeństwa na etapie projektowania.